PRAVEEN V 241901082

Exercise 4

Detect Session Hijacking

AIM

To detect session hijacking attempts on a network/web application by analyzing network traffic, session parameters and system logs using tools such as Wireshark, IDS (Snort) and server-side session monitoring.

PROCEDURE

Part A: Detection Using Wireshark (Traffic Analysis)

1. Open Wireshark on the monitoring machine and start capturing packets on the network interface.
2. Apply the filter to view HTTP traffic with cookies: http.cookie
3. Observe the session ID values across multiple packets.
4. Check for the same session ID (PHPSESSID/JSESSIONID) being used from two different source IP addresses or MAC addresses — this indicates possible hijacking.
5. Use the filter ip.addr == <victim IP> and ip.addr == <suspected attacker IP> to compare requests carrying the identical session cookie.
6. Check for abnormal sequence numbers or duplicate ACKs, which may indicate TCP session hijacking/injection.

Part B: Detection Using ARP Monitoring

1. On the victim/monitoring machine, check the ARP table:
   arp -a
2. Look for duplicate IP addresses mapped to different MAC addresses, which indicates ARP spoofing (used to enable hijacking).
3. Use arpwatch to continuously monitor ARP changes:
   arpwatch -i eth0
4. Note any "new station" or "flip flop" alerts, which indicate a possible man-in-the-middle/session hijacking attempt.

Part C: Detection Using IDS (Snort)

1. In Kali Linux, configure and run Snort in IDS mode:
   snort -A console -q -c /etc/snort/snort.conf -i eth0
2. Add/verify a rule to detect session hijacking indicators such as repeated session cookie use from different IPs:
   alert tcp any any -> any any (msg:"Possible Session Hijacking - Duplicate Cookie"; content:"Cookie|3a|"; sid:1000001;)
3. Monitor the console/alert log while traffic is generated from two different machines using the same session ID.
4. Observe the alert triggered by Snort confirming the detection.

Part D: Server-Side Detection

1. Check the web server/application session logs for the same session ID being used with two different IP addresses or User-Agent strings within a short time span.
2. Enable session-IP binding (if available) on the server so that any mismatch between the stored IP and request IP is logged/flagged.

3. Note down the timestamps and IP addresses of the suspicious duplicate session usage.

OBSERVATION TABLE

S.No	Detection Method	Tool Used	Observation
1	HTTP cookie comparison	Wireshark	Same session ID seen from two different IPs
2	TCP anomaly check	Wireshark	Abnormal sequence numbers / duplicate ACKs found
3	ARP table check	arp -a	Duplicate IP mapped to two different MAC addresses
4	Continuous ARP monitoring	arpwatch	"Flip flop" alert generated for victim IP
5	IDS rule-based detection	Snort	Alert triggered for duplicate session cookie
6	Server log analysis	Session/Access logs	Same session ID used with different IP/User-Agent

OUTPUT

Wireshark – duplicate session from two IPs:

PRAVEEN V 241901082

192.168.1.10 -> Cookie: PHPSESSID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e

192.168.1.15 -> Cookie: PHPSESSID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e

arp -a output:

192.168.1.1 aa-bb-cc-dd-ee-ff

192.168.1.10 11-22-33-44-55-66

192.168.1.10 77-88-99-aa-bb-cc <-- duplicate IP, different MAC

arpwatch alert:

hostname: victim

ip address: 192.168.1.10

ethernet address: 77-88-99-aa-bb-cc

old ethernet address: 11-22-33-44-55-66

flip flop

Snort alert output:

[**] [1:1000001:0] Possible Session Hijacking - Duplicate Cookie [**]

[Priority: 0]

10/27-14:32:10.123456 192.168.1.15:52344 -> 44.228.249.3:80

Server log entry:

SessionID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e | IP=192.168.1.10 | UserAgent=Chrome | 14:30:05

SessionID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e | IP=192.168.1.15 | UserAgent=Firefox | 14:32:10 <-- mismatch flagged

RESULT

Thus, session hijacking attempts were successfully detected on the target network/web application using Wireshark traffic analysis, ARP monitoring, Snort IDS and server-side session log analysis. Duplicate session usage from different IP addresses/MAC addresses was identified, confirming the presence of a hijacking attempt.